

Eco eco-routes-svm PR 41

Security Review

Cantina Solo review by:
Rikard Hjort, Lead Security Researcher

March 24, 2026

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
2.1	Reviewer Statement	3
3	Findings	4
3.1	Low Risk	4
3.1.1	Inability to pause message handling in case of Hyperlane ISM compromise	4
3.2	Informational	4
3.2.1	README does not reflect reliance on Mailbox default ISM	4

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

A security review is a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While the review endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that a security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Eco is a protocol building intent-based bridging infrastructure. The eco-routes-svm project implements Eco's intent settlement routes on Solana-compatible chains. This review covers PR 41, which integrates Hyperlane as the cross-chain messaging layer, replacing custom ISM implementations with reliance on the Hyperlane Mailbox's default Interchain Security Module (ISM).

From Mar 23rd the security researchers conducted a review of `eco-routes-svm` on commit hash `d4eebd80`. A total of **2** issues were identified:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	1	0	1
Gas Optimizations	0	0	0
Informational	1	1	0
Total	2	1	1

2.1 Reviewer Statement

The main concern was the trust shift to Hyperlane's operational security, with a recommendation to add a pause mechanism to `handle()` as a kill switch for a compromised ISM upgrade. The Eco team acknowledged this risk but chose not to add the pause, citing confidence in Hyperlane's default ISM; they did complete the requested README update.

PR 41 updates `eco-routes-svm` to integrate Hyperlane recipient hooks and rely on the Mailbox's default ISM for cross-chain message verification instead of a custom ISM. The `handle()` function validates incoming messages by sender whitelist only; origin chain is not checked, consistent with existing `eco-routes` behavior.

- `eco-routes-svm` trusts the Hyperlane Mailbox and default ISM to verify cross-chain messages; compromise of the default ISM would directly affect protocol security.
- The Mailbox is static and cannot be changed, leaving no recourse if it is compromised.
- The sender whitelist in `handle()` is assumed to be correctly configured; no origin-chain validation is performed.

3 Findings

3.1 Low Risk

3.1.1 Inability to pause message handling in case of Hyperlane ISM compromise

Severity: Low Risk

Context: `handle()` function in `eco-routes-svm`

Description: The change to rely on the Hyperlane Mailbox's default ISM shifts trust to Hyperlane's operational security. The Mailbox contract is static and cannot be changed. If Hyperlane's ISM were to be compromised or upgraded to a faulty version, there is currently no mechanism in `eco-routes-svm` to quickly halt message processing. This could leave the protocol exposed during the window between a compromise and a manual intervention.

Recommendation: Consider adding a pause mechanism to `handle()` (or equivalent) to allow the Eco team to quickly disable cross-chain message processing in the event of a detected compromise on the Hyperlane side. This would maintain the level of operational security the protocol has had until this point.

Eco: The team decided not to implement the pause at this time, as they are using the default ISM rather than a custom one and trust Hyperlane to keep it operational.

Rikard Hjort: Acknowledged.

3.2 Informational

3.2.1 README does not reflect reliance on Mailbox default ISM

Severity: Informational

Context: README documentation in `eco-routes-svm`

Description: The README states that the program "implements ISM", which is technically true in that it implements the `ism()` interface, but it does not actually implement a custom ISM. The program now relies on the default ISM from the Hyperlane Mailbox. This is misleading and could cause confusion for developers and auditors reviewing the codebase.

Recommendation: Update the README to clarify that the program implements Hyperlane recipient hooks and relies on the default ISM from the Mailbox, rather than implementing or setting its own ISM.

Eco: Acknowledged and addressed.

Rikard Hjort: Fixed in [PR 41](#) -- README and comments updated.